

Security incident report

Section 1: Identify the network protocol involved in the incident

The primary protocol involved in the incident was HTTP because the compromised website used HTTP to deliver the malicious file. The traffic log also shows DNS and IPv4 supporting the communication: DNS resolved the domain name, while IPv4 carried packets between the devices.

Section 2: Document the incident

Attack Vector:

The attacker successfully executed a brute-force attack against the web host's administrative ("admin") account, which was secured with an unchanged default password.

Impact & Exploitation:

Upon gaining unauthorized access, the attacker modified the website's source code to prompt visiting users to download a malware-laden file. Once executed, this file redirects users to an external malicious site (greatrecipesforme.com). To delay remediation, the attacker altered the admin account password, locking out authorized administrators.

Investigation Steps:

1. Incident Discovery: Suspicious activity was identified after receiving reports from users about the download and redirection, as well as, the website owner discovering loss of administrative access due to an unauthorized password change.
2. Analysis: The website was accessed within a sandboxed virtual machine environment to analyze the malicious payload prompts and trace network activity using the tcpdump log.
3. Verification: The redirection to the malicious external domain was observed, and a senior analyst confirmed that the source code had been altered as a result of the default password vulnerability.

Section 3: Recommend one remediation for brute force attacks

This incident could have been avoided had the security method of limiting the number of login attempts before locking the account. This method would have made it more difficult for the attacker to cycle through the list of known admin passwords before finding the correct one.